



400-650-7088

TongWeb v8.0

安全加固手册

文档版本：809XXA02

2025年06月

声明

版权

Copyright ©2025北京东方通科技股份有限公司或其关联公司（以下简称“东方通”）。保留所有权利。

版权声明

- 本文档的所有权和知识产权归属于东方通所有。
- 除非另有明确约定，东方通不授予任何明示或暗示的许可或权利，使用者不得以任何方式将本文档中的任何内容用于商业目的。
- 东方通对本文档享有版权。本文档的所有内容，包括但不限于文字、图像、图表、图标、示意图、屏幕截图等，均受版权法和国际版权条约的保护。
- 未经东方通明确授权，任何人不得对本文档以任何形式复制、修改、传播、分发、展示或进行衍生创作。

商标声明

- **东方通**、**TongTech** 标识以及其他相关东方通图形、徽标、服务名称和商标（以下统称为“东方通商标”）是东方通或其关联公司的注册商标或商标。
- 未经东方通明确授权，任何人不得以任何方式使用、复制或展示东方通商标。此外，未经东方通事先书面同意，不得将东方通商标与其他商标、标识或徽标进行混淆、链接或结合使用。
- 除非另有明确约定，本商标声明不授予任何明示或暗示的许可或权利，对东方通商标的使用须获得东方通的明确授权。
- 本文档提及的所有其他商标、标识、徽标或产品名称均为其各自所有者的财产，并可能受其各自的商标法保护。

免责声明

请在使用东方通产品之前仔细阅读本免责声明，并根据自身情况判断是否继续使用。如有任何问题，请联系我们的客户支持团队。

- 本产品的使用是基于用户自己的判断和风险评估。本文档仅作为使用指导，不对使用本产品所产生的结果做任何明示或暗示的担保。
- 东方通不对用户未按照本文档中的指导正确使用东方通产品而导致的任何损失或损害承担责任；
- 本文档可能会包含第三方提供的内容、链接或资源，这些内容由第三方自行负责。东方通对于这些内容的准确性、完整性、合法性或可靠性不承担责任。用户在使用这些内容时应自行判断和承担风险。
- 由于产品版本升级或其他原因，本文档内容会不定期更新。东方通保留在不事先通知用户的情况下随时对文档进行修改、更新或中止的权利。

如需获取有关东方通产品的许可或使用权，请联系东方通或授权代理商。任何违反本声明的行为将受到适用法律的追究。

版本变更说明

本章节记录了 8.0.9.XX 版本的所有变更说明。

• A02

序号	功能模块	功能说明	相关章节
1	安全管理 > 安全策略 > 通信	将“序列化安全”页签名称修改为“通信”。	序列化安全

• A01

首次发版。

前言

本文档主要面向用户和技术支持人员，本文档对 TongWeb 常见的安全加固配置方法进行说明。

提示：

- 本文档不再详细描述配置步骤，具体请看 TongWeb 手册或由东方通支持人员协助配置及验证。
- 本文档中有些参数、xml配置在复制、粘贴时，注意文本格式以免执行出错。

为保证产品安全，首先建议升级到TongWeb最新版本，新版本会解决目前已知的安全漏洞。

产品安全漏洞补丁可从东方通官方网站进行下载，地址为：<https://www.tongtech.com/dft/download.html>

国家信息安全漏洞共享平台（CNVD）中已公布的TongWeb应用服务器漏洞如下：

查询地址为：<https://www.cnvd.org.cn/>

编号：	请输入精确编号	开始时间：		结束时间：		提交	高级搜索
漏洞标题	危害级别	点击数	评论	关注	时间↓		
✦ TongWEB应用服务器存在文件上传漏洞	高	5	0	0	2022-03-17		
✦ TongWEB应用服务器存在任意文件下载漏洞	中	5	0	0	2022-03-17		
✦ TongWEB应用服务器存在任意文件上传漏洞	高	5	0	0	2022-03-17		
✦ TongWeb管理控制台存在命令执行漏洞	高	74	0	0	2021-08-07		
✦ TongWeb管理控制台存在文件上传漏洞	高	63	0	0	2021-08-02		
✦ 北京东方通科技股份有限公司TongWeb管理控制...	中	63	0	0	2021-08-02		
✦ 北京东方通科技股份有限公司TongWeb管理控制...	中	64	0	0	2021-08-02		

阅读前注意事项

通过阅读本文档，您确认并同意自行承担因未具备必要专业背景和知识而导致的任何风险或后果。在使用本文档中提供的信息和指南时，请始终谨慎，并在必要时寻求专业人士建议和指导。

• 适用对象

本文档主要适用于使用本产品的系统管理员阅读，部分内容同样适用于基于本产品进行应用开发或应用部署的人员阅读。

• 专业背景

本文内容可能涉及到操作系统、服务器硬件、网络等相关领域的知识。请确保您具备相关背景和知识，以便更好地理解和应用本手册的内容。

• 技能要求

为了能够充分理解和应用本文档的内容，建议您具备如下技能：

- 基本系统管理任务
- 掌握 Linux 系统基本操作
- 在终端窗口发布命令
- 使用 Web 浏览器
- 安装软件
- 术语和概念

本文档可能使用一些专业术语和概念。请确保您熟悉这些术语和概念，或者有能力查阅相关资料以便进一步理解。

- 实践经验

为了最大程度地受益于本文档，建议您具备一定实践经验。这将帮助您更好地应用文档中的操作指南和建议。

请注意，本文档不适用于没有相关专业背景和知识的用户。如果您对本文档的内容或所需背景有任何疑问，请在使用之前咨询相关专业人士或寻求额外的支持。

用户手册集

TongWeb 为您提供如下用户使用手册。

用户手册	说明
000_TongWeb_V8.0产品对比手册	详细介绍了 TongWeb 的版本差异以及如何选择 TongWeb 的产品等。
001_TongWeb_V8.0产品介绍手册	详细介绍了 TongWeb 的概述、体系结构、版本功能对比等信息。
002_TongWeb_V8.0安装与使用指引	详细介绍了 TongWeb 各平台上的安装启动、版本切换等说明。
003_TongWeb_V8.0控制台使用手册	详细介绍了 TongWeb 管理控制台对应用进行部署、管理操作等说明。
004_TongWeb_V8.0命令行工具手册	详细介绍了 TongWeb 命令行工具的使用说明。
005_TongWeb_V8.0REST API手册	详细介绍了 TongWeb REST 接口的使用说明。
006_TongWeb_V8.0常见问题手册	详细介绍了使用 TongWeb 过程中遇到的常见问题及解决方案。
007_TongWeb_V8.0安全加固手册	详细介绍了 TongWeb 常见的安全加固配置方法说明。
008_TongWeb_V8.0容器化部署手册	详细介绍了 TongWeb 在容器上的部署说明。

技术支持

东方通产品将为您提供全方位的技术支持，您可以通过以下方式获得技术支持：

- 网址：www.tongtech.com
- 电话：400-650-7088
- 邮箱：support@tongtech.com

您在取得技术支持时，请提供如下信息：

- 您的姓名
- 您的公司信息
- 您的联系方式
- 操作系统及其版本
- 产品版本号
- 日志等错误的详细信息

目录

声明	1
版本变更说明	2
前言	3
1. TongWeb 自身安全配置项	7
1.1. 以普通用户安装 TongWeb	7
1.2. TongWeb 使用端口及防火墙开通策略	7
1.3. 可选择性的关闭 TongWeb 控制台	7
1.4. 开启动态密码	8
1.5. 修改 TongWeb 默认密码	8
1.6. 设置信任 IP	8
1.7. 开启访问日志	9
1.8. 控制台禁止远程文件上传	9
2. 应用相关安全配置项	11
2.1. 会话与Cookie	11
2.2. 应用安全配置项	12
2.3. 全局安全策略	17
2.3.1. 文件防篡改	17
2.3.2. 客户端拦截	18
2.3.3. 协议头安全	19
2.3.4. 支持 XFF	21
2.3.5. 反爬虫	22
2.3.6. 禁用时间段	23
2.3.7. 启停安全	24
2.3.8. 序列化安全	25
2.4. 在虚拟主机中自定义错误页面	26
3. SSL 配置相关	28
3.1. 关于 SSL 安全配置	28
3.2. http 强制跳转 https 端口	29

1. TongWeb 自身安全配置项

本章节主要介绍 TongWeb 自身安全配置项，基本不影响应用，为建议配置项。

1.1. 以普通用户安装 TongWeb

在 Linux 操作系统以普通用户安装并运行 TongWeb，避免采用 root 用户导致 TongWeb 权限过大。

 若项目需要使用 80 端口，仍需 root 用户。

1.2. TongWeb 使用端口及防火墙开通策略

防火墙设置基本原则：对外用户访问只暴露应用访问端口，其它端口为 TongWeb 内部进程通信端口，只需对内放开，切勿对外暴露。

 禁止在互联网暴露 9060/console 控制台，会被当做攻击对象。

服务程序	功能	默认端口	端口作用
TongWeb	提供服务的核心进程	8088	默认应用访问端口
		9060	默认控制台端口
		7200	JMX端口，默认关闭
		5200	EJB w3 远程端口，默认关闭
TongWeb MQ	消息服务器	7676	JMS 服务端口
TongDataGrid	内存会话服务器	5701	session 复制端口

1.3. 可选择性的关闭 TongWeb 控制台

TongWeb 控制台为常被攻击的对象，在不常使用 TongWeb 控制台维护的情况下，可删除“\${tongweb.base}/conf/tongweb.xml”中的 <connector> 关闭控制台，如下图所示。

```
<?xml version="1.0" encoding="UTF-8" standalone="no"?>
<!-- 注意事项 -->
<!-- TongWeb 的配置文件 tongweb.xml、console.xml 等，默认开启了防篡改功能 -->
<!-- 在 TongWeb 运行期间，您可能无法对其进行手动编辑（相关操作可能会自动回退） -->
<!-- 若您确实需要手动编辑这些文件，请先停止 TongWeb，之后再行进行相关操作即可 -->
<!-- -->
<tongweb compatibleToVersion="8.0.0">
  <java-config workDir="${tongweb.base}">
    <environments>
      <env enabled="false" name="JAVA_HOME" value="" />
    </environments>
    <start-args>
    </start-args>
  </java-config>
  <server ExtremeMode="1" autoDeploy="false">
    <service systemManaged="true">
      <connector SSLEnabled="true" address="0.0.0.0" clientAuth="false" keystoreFile="conf/server.keystore" keystorePass="jo+fvRppEjYJWnAqSYOpfg==" maxSwallowSize="2097152"
        maxThreads="24" minSpareThreads="5" name="admin" port="9060" scheme="https" secure="true" sslEnabledProtocols="TLSv1.2" sslProtocol="TLSv1.2" systemManaged="true"
        truststoreFile="conf/server.keystore" truststorePass="jo+fvRppEjYJWnAqSYOpfg==" />
      <container defaultHost="admin" name="admin" systemManaged="true">
        <host name="admin" systemManaged="true" />
      </container>
    </service>
  </server>
</tongweb>
```

影响范围：这期间无法使用 TongWeb 控制台。

1.4. 开启动态密码

因 TongWeb 一般安装在内网，邮件认证不便，可通过动态密码方式开启动态密码，该扫码方式无需 TongWeb 联网，具体操作见《TongWeb_V8.0控制台使用手册》。

修改密码 ⓘ / 编辑 ☆

修改密码 ⓘ ☒

* 原始密码 ⓘ

* 新密码 ⓘ

* 确认密码 ⓘ

动态密码 ⓘ ☐

更新

刷新动态密码

影响范围：登录 TongWeb 控制台需要手机扫码登录。

1.5. 修改 TongWeb 默认密码

首次登录 TongWeb 控制台需修改密码。

! 除修改 thanos 密码外，另外三个用户 security、auditor、monitor 也需要修改默认密码。

影响范围：因修改控制台密码后可能会忘记密码造成不便，所以请妥善保管密码。

1.6. 设置信任 IP

限制访问控制的客户端 IP 可进行如下设置，切忌设置为 *。

控制台安全 / 编辑 ☆

基本属性

OAuth2

* 访问前缀 ?

console

信任 IP ?

禁用文件上传

指定信任的客户端 IP 地址，其值可为具体的 IP、匹配 IP 的正则表达式或通配符（如：168.1.2.*，168.1.4.5-168.1.4.99）。远程的客户端只有在被设置为信任后，才可进行首次默认密码更改、文件上传等敏感操作。注：不设置表示只有 TongWeb 的安装机器受信任，设置为 * 表示信任所有机器（不建议）。

禁用文件下载

失败锁定次数

锁定时长 ?

300

会话超时时间 ?

15

启用验证码 ?

☒

影响范围：TongWeb 控制台只允许指定的客户端 IP 访问。

1.7. 开启访问日志

访问日志默认没有开启，开启访问日志需登录控制台，在日志管理中开启访问日志配置。

访问日志配置 / 编辑 ☆

基本属性

日志文件

在线日志

启用访问日志 ?

☒

* 作用到虚拟主机 ?

☒ admin ☒ localhost ☐ test

使用自定义格式 ?

☐

* 日志内容 ?

时间

客户端 IP

请求方法

协议

Http 状态码

请求地址

发送字节数

会话 ID

线程名

客户端域名

本地端口

应用名

记录请求头 ?

记录响应头 ?

记录 Cookie ?

记录 Session ?

影响范围：无，在遭受客户端攻击时，可通过访问日志分析客户端来源。

1.8. 控制台禁止远程文件上传

控制台安全 ⓘ / 编辑 ☆

基本属性

OAuth2

* 访问前缀 ⓘ

console

信任 IP ⓘ

禁用文件上传 ⓘ

☒

禁用文件下载 ⓘ

失败锁定次数 ⓘ

锁定时长 ⓘ

200

会话超时时间 ⓘ

15

启用验证码 ⓘ

☒

禁用文件上传 ⓘ

禁用文件上传可以在很大程度上保护系统的安全，禁用后，攻击者将不能再通过 TongWeb 控制台来进行部署木马应用、上传恶意程序等操作。禁用文件上传后，您仍然可以选择服务器上已有的文件来进行相关操作。注：出于安全考虑，建议保持禁用文件上传功能。

影响范围：无法通过控制台上传应用包。

2. 应用相关安全配置项

以下为应用相关安全配置项，从安全角度需要开启，但开启后可能会影响到应用正常使用，请酌情考虑。

2.1. 会话与Cookie

应用 / 部署 ☆

基本属性

资源加载

会话与Cookie

JSP

编码

性能

安全

SHTML

其它

会话的Cookie名 ?

使用老版 Cookie 处理器 ?

Cookie HttpOnly ?

Cookie SameSite ?

Unset

None

Lax

Strict

最大会话数 ?

100000

会话超时时间 ?

30

会话服务器 ?

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>applications>app

Table 1. 应用的【会话与Cookie】

参数	名称	参数说明
sessionCookieName	会话的 Cookie 名	指定应用会话的 Cookie 名称。注：若应用的 web.xml 中同样设置了该属性，则优先使用 web.xml 中的值。若以上两处都没有设置，则使用默认的 JSESSIONID 作为名称。
useLegacyCookieProcessor	使用老版 Cookie 处理器	使用老版 Cookie 处理器，是基于 RFC6265、RFC2109、RFC2616的，开启后可兼容基于 Tomcat 8 以前版本开发的应用。
allowEqualsInValue	Cookie Equal Signs	如果是 true ，则在解析未加引号的 Cookie 值时允许使用等号字符。如果是 false ，当遇到等号时，包含等号的 Cookie 值将被终止，并且剩余的 Cookie 值将被删除。
allowHttpSepsInV0	HTTP 分隔符	如果是 true ，则允许在 Cookie 名称和值中使用 HTTP 分隔符。
useHttpOnly	Cookie HttpOnly	会话 Cookie 是否使用 HttpOnly 标志。

参数	名称	参数说明
sameSiteCookies	Cookie SameSite	设置 Cookie 的 SameSite 属性。Unset：不要设置 SameSite Cookie 属性；None：Cookie 始终在跨站点请求中发送；Lax：Cookie 仅在同站点请求和跨站点顶级导航 GET 请求上发送；Strict：防止浏览器在所有跨站点请求中发送 cookie。
maxActiveSessions	最大会话数	限制该应用同时在线的最大会话数，以防止会话过大导致系统瘫痪。设置为“-1”表示不限制。
sessionTimeout	会话超时时间	设置应用会话（Session）的超时时间（单位：分钟）。
localPersistence	本地持久化	开启后，应用在停止时会将当前内存中的会话持久化存储到本地，如文件系统，并在启动后重新载入内存。本地持久化为异步进行，受“全局配置”中“定时任务周期”影响，若 TongWeb 进程被强杀（如执行了 forcestop 脚本）则最多会丢失最近一个“定时任务周期”内写入的会话数据。
refSessionHa	会话服务器	选择应用要连接的会话服务器，将应用的 Session 存储到会话服务器。其优先级高于虚拟主机设置的会话服务器；但若虚拟主机同时开启了“Session共享”则优先级低于虚拟主机的会话服务器。注：当由于网络等原因导致会话服务器不可用时，应用的 Session 仍会在本地内存中存取，不会中断应用的业务处理。

2.2. 应用安全配置项

应用 / 部署 ☆

基本属性

资源加载

会话与Cookie

JSP

编码

性能

安全

SHTML

其它

允许跨域访问 ?

参数防丢失 ?

XSS 攻击拦截 ?

CSRF 防护 ?

应用密级 ?

普通

机密

绝密

业务安全规则 ?

单线程池

双线程池

多线程池

并发安全控制 ?

限定访问端口 ?

server

允许跨应用访问 ?

卸载等待 ?

20

允许链接文件 ?

内存泄漏检测 ?

应用回收 ?

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>applications>app

Table 2. 应用的【安全】

参数	名称	参数说明
enableCORSAccess	允许跨域访问	通过为资源实现 W3C 的 CORS（跨域资源共享）规范来启用客户端跨域请求。
corsAllowedOrigins	允许的源	设置允许跨域访问的源，配置多个源使用英文逗号分隔，例如 http://www.xxx.com , http://www.zzz.com 。注：设置为 “*” 表示所有源都允许。
corsAllowedMethods	允许的方法	允许跨域访问的方法，默认支持 GET,POST,HEAD,OPTIONS。配置多个方法以英文逗号分隔，例如 GET,POST,HEAD,OPTIONS。

参数	名称	参数说明
corsAllowedHeaders	允许的 HTTP 头	允许的 HTTP 头，XMLHttpRequest 对象的 <code>getResponseHeader()</code> 方法拿到的基本字段，默认支持 <code>Origin,Accept,X-Requested-With,Content-Type,Access-Control-Request-Method,Access-Control-Request-Headers</code> ，配置多个 HTTP 头以英文逗号分隔。
corsExposedHeaders	暴露 HTTP 头	通过 <code>Access-Control-Expose-Headers</code> 暴露指定的 HTTP 头， <code>Access-Control-Expose-Headers</code> 标头指示哪些标头可以安全地公开给 CORS API 规范的 API。注：配置多个 HTTP 头以英文逗号分隔。
corsSupportCredentials	支持凭证	CORS 请求默认不发送 Cookie 和 HTTP 认证信息。若需要把 Cookie 发到服务器，则设置为“true”，默认为“false”。
corsPreflightMaxAge	预检请求的有效期	用来指定本次预检请求的有效期（单位：秒）。在此期间，不用发出另一条预检请求，默认值 1800 秒。
requestParametersLostValidation	参数防丢失	开启该功能后，若请求参数解析期间出现故障（如请求参数个数超过了设置的阈值或 POST 数据的大小超过了设置的阈值等），系统将拒绝请求，以确保客户端提交的参数值不会丢失。
XSSFilterEnabled	XSS 攻击拦截	拦截可疑的 XSS 攻击请求，通常是含有 <code>script</code> 、 <code><</code> 、 <code>></code> 等特殊标记的请求，以 403 响应码返回到客户端。
csrfPrevention	CSRF 防护	注意：请谨慎打开此功能，否则可能导致应用无法访问！！为 Web 应用提供基本的 CSRF 防护支持，该功能需要应用自身予以配合：调用 <code>HttpServletResponse#encodeRedirectURL(String)</code> 和 <code>HttpServletResponse#encodeURL(String)</code> 方法（每执行一次则产生一个新的令牌，当 CSRF 令牌缓存数设置为 0 时，一个会话只产生一个令牌）编码 URL 后发送到客户端，其目的是要发送回服务器的 URL 都带有 <code>csrf.token</code> 参数以认证身份。编码后的 URL 示例： <code>/myservlet/myres?param=val&csrf.token=...</code> TongWeb 的 CSRF 防护同时可以阻挡重放攻击，只要不将 CSRF 令牌缓存数设置为 0 即可。

参数	名称	参数说明
csrfCacheSize	CSRF 令牌缓存数	CSRF 令牌会随着客户端请求而更新，CSRF 令牌缓存数表示保留最新的令牌个数，这同时也表示允许的客户端并发数。0 表示不限制。
tokenValidTimes	CSRF 令牌有效次	提供 CSRF 令牌循环使用支持，使用次数超出有效次后会自动失效，可用于资源需要重复访问而不支持及时更新 CSRF 令牌等场景。注意：1. CSRF 令牌允许循环使用时，将无法阻挡重放攻击；2. 该功能仅在“CSRF 令牌缓存数”不为 0 时有效。
csrfEntryPoints	CSRF 免防入口	开启 CSRF 防护后，可选设置一些免防入口（应用 URL），如登录资源，以跳过防护检查。设置多个入口时，使用英文逗号分隔。
httpHeaderToken	REST 支持	开启了 CSRF 防护的应用，将无法使用 REST 接口，原因是 REST 接口无法通过 URL 传递令牌，开启“REST 支持”可解决该问题。开启“REST 支持”需要应用自身予以配合： 1. 客户端须首先请求免防资源，服务器通过响应头返回令牌； 2. 客户端请求其它资源须通过请求头（名为：csrf.token）回传服务器令牌，以通过服务器的安全认证。
secretLevel	应用密级	设置本应用的保密等级，此保密等级将用于应用数据网络传输、主体数据存取、客体请求访问等过程的加密处理。
threadPoolPolicy	业务安全规则	1（单线程池）：使用通道内置的线程池处理所有业务； 2（双线程池）：符合规则的业务由线程池处理，其它业务由通道内置的线程池处理； 3（三线程池）：符合规则的业务由线程池处理，其它业务由其它线程池处理。线程池不会作用的范围：由服务器处理的静态资源、支持异步 Servlet 处理的业务。注意：对于使用了异步 Filter 的业务，请谨慎或不要使用线程池功能。注意：若业务处理时间过长（如超过 30 秒），则建议增大线程超时阈值，否则可能导致请求失败！
threadPool	线程池	线程池功能可将指定的业务交给指定的线程池来处理，可支持应用根据业务的重要性、优先级等方面约束系统资源的使用。该功能一般适用于并且只建议应用于比较耗时的业务操作，例如长事务、远程服务调用等。

参数	名称	参数说明
threadPoolTimeout	线程超时阈值	业务处理时长达到该阈值后，响应结果将即刻发送回客户端，而不再等待线程处理结束，这会提高整体的响应效率，但可能导致客户端没有获取到最终的处理结果。单位是毫秒，0 表示使用通道的异步请求的默认超时。
taskRule	匹配规则	指定需要线程池执行的业务的匹配规则，其格式须是匹配 URL 的正则表达式。不指定则表示可接受所有业务。注：业务的匹配规则是基于请求的 Servlet 路径，而不包含应用的访问名。
exclusionRule	排除规则	指定需要线程池从匹配规则中要排除的业务规则，其格式须是匹配 URL 的正则表达式。不指定则表示不排除。注：业务的匹配规则是基于请求的 Servlet 路径，而不包含应用的访问名。
otherThreadPool	其它线程池	当使用三线程池策略时，符合规则的业务由线程池处理，其它业务由其它线程池处理。
otherThreadPoolTimeout	其它线程超时阈值	其它业务处理时长达到该阈值后，响应结果将即刻发送回客户端，而不再等待线程处理结束，这会提高整体的响应效率，但可能导致客户端没有获取到最终的处理结果。单位是毫秒，0 表示使用通道的异步请求的默认超时。
semaphoreEnabled	并发安全控制	出于安全等考虑，控制访问应用的并发量。
concurrency	限制最大并发	允许的最大并发访问量。
block	阻塞等待	当应用达到最大并发访问量时，是否阻塞等待访问应用。若不等待，请求会被终止，并记录一条日志。
interruptible	允许中断阻塞	当请求线程在阻塞等待访问应用时，是否允许被中断，若被中断则请求会被终止，并记录一条日志。
restrictedPorts	限定访问端口	限定访问端口后，只有指定的端口可以访问本应用，其它端口的访问会被拒绝，不指定则表示不限制。可用于支持系统应用、重要应用、普通应用的端口隔离式的安全访问，并可通过设置不同端口的资源大小来约束不同应用的业务处理效率。注意：该功能只适用于 Web 应用，对于远程访问的 EJB 应用无效。

参数	名称	参数说明
crossContext	允许跨应用访问	指定是否允许调用 ServletContext.getContext("/appName") 方法访问此服务器中其他 Web 应用程序的上下文。
unloadDelay	卸载等待	卸载应用时，若存在请求未处理完毕，则等待一段时间（单位：秒），超时后会强制卸载，此时会给出线程泄漏的警告日志。
allowLinking	允许链接文件	是否允许使用软链接访问应用的资源文件。
clearReferences	内存泄漏检测	在应用停止时，检查并尝试回收与应用相关联的可能导致内存泄漏的JDBC驱动、线程、线程局部变量（ThreadLocal）、Java 序列化对象缓存、RMI 目标对象等资源。
enableRecycling	应用回收	启用后，应用卸载时将备份到回收站，可在应用回收列表查看。

2.3. 全局安全策略

2.3.1. 文件防篡改

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

通信

服务器主配置文件防篡改 ⓘ ☒

应用防篡改文件后缀 ⓘ

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 3. 安全策略的【文件防篡改】

参数	名称	参数说明
configProtection	服务器主配置文件防篡改	开启后，禁止在 TongWeb 运行期间对主配置文件 tongweb.xml、console.xml、default-web.xml 等进行修改。若被意外篡改，则自动进行恢复。

参数	名称	参数说明
fileProtectionPattern	应用防篡改文件后缀	指定应用的防止篡改的文件的后缀。在应用部署后，对应用的所有原始文件进行周期性（由服务器“全局配置”>“定时任务周期”指定）的检测。当发现文件被篡改后，尝试恢复到原文件。配置防篡改文件后缀，表示开启该功能；不配置，则不开启。防篡改文件后缀格式为 .html, .png, .jpg 等，多个后缀以英文逗号分隔。注意：同时开启热加载和防篡改功能，可能存在冲突，建议不要同时开启。

2.3.2. 客户端拦截

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

序列化安全

客户端主机名拦截 ⓘ

客户端 IP 拦截 ⓘ

SDOS 攻击拦截 ⓘ

SDOS 探测阈值 (秒) ⓘ

SDOS 次数阈值 ⓘ

解除阻止周期 (小时) ⓘ

1

3

12

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 4. 安全策略的【客户端拦截】

参数	名称	参数说明
filterRemoteHost	客户端主机名拦截	出于安全等考虑，拦截特定主机名的客户端请求，请求被拦截后将得到 403 响应码。注：本机访问不受限制。
allowHost	允许的主机名	指定允许的主机名，其值可为具体的主机名称或匹配主机名称的正则表达式。注：需要通道允许 DNS 反向查找。
denyHost	拒绝的主机名	指定拒绝的主机名，其值可为具体的主机名称或匹配主机名称的正则表达式。注：需要通道允许 DNS 反向查找，拒绝的主机名拦截优先于允许的主机名。
filterRemoteAddr	客户端 IP 拦截	出于安全等考虑，拦截特定 IP 的客户端请求，请求被拦截后将得到 403 响应码。注：本机访问不受限制。

参数	名称	参数说明
allowAddr	允许的 IP	指定允许的 IP，其值可为具体的 IP、匹配 IP 的正则表达式或通配符 IP（如：168.1.2.*，168.1.4.5-168.1.4.99）。
denyAddr	拒绝的IP	指定拒绝的IP，其值可为具体的 IP、匹配 IP 的正则表达式或通配符 IP（如：168.1.2.*，168.1.4.5-168.1.4.99）。注：拒绝的 IP 拦截优先于允许的 IP。
denySdos	SDOS 攻击拦截	检测并拦截 SDOS 攻击。
sdosTimeThreshold	SDOS 探测阈值（秒）	当一个请求的处理时间超过此 SDOS 探测阈值时，则将该请求判定为 SDOS 攻击。
sdosCountThreshold	SDOS 次数阈值	当一个客户端（通常是浏览器）发出的请求被判定为 SDOS 攻击的次数超过此 SDOS 次数阈值，则阻止该客户端 IP 地址的一切请求。
sdosUnblockPeriod	解除阻止周期（小时）	被阻止的客户端 IP 将在一个周期后自动解除。

2.3.3. 协议头安全

安全策略 / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

序列化安全

Host Header 拦截 ?

referer 拦截 ?

响应头防护 ?

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 5. 安全策略的【协议头安全】

参数	名称	参数说明
hostHeaderFilter	Host Header 拦截	开启 Host Header 拦截后，将会从请求头“Host”中解析主机名和 IP 地址，只有符合规则请求才可以访问本主机。注：本机访问不受限制。

参数	名称	参数说明
allowHostHeader	允许的 Host	支持正则表达式，依照此规则对 Host 中的主机进行校验，如192.168.1.([0-9]*):9060 www.tw.com；未设置此规则，表示不进行该校验。注：“允许的 Host”校验的优先级低于“拒绝的 Host”。
denyHostHeader	拒绝的 Host	支持正则表达式，依照此规则对 Host 中的主机进行校验，如192.168.1.([0-9]*):9060；未设置此规则，表示不进行该校验。注：“允许的 Host”校验的优先级低于“拒绝的 Host”。
refererFilter	referer 拦截	开启 referer 拦截后，将会从请求头“referer”中解析主机名和IP地址。只有符合规则请求才可以访问本主机。注：本机访问不受限制。
allowReferer	允许的 referer	指定允许访问本主机的域名或者 IP，支持正则表达式。依照此规则对 referer 中的主机进行校验。未设置此规则，表示不进行该校验。注：“允许的 referer”校验的优先级低于“拒绝的 referer”。
denyReferer	拒绝的 referer	指定不允许访问本主机的域名或者 IP，支持正则表达式。依照此规则对 referer 中的主机进行校验。未设置此规则，表示不进行该校验。注：“允许的 referer”校验的优先级低于“拒绝的 referer”。
responseHeader	响应头防护	可对响应头添加特定的消息，以通知浏览器进行必要的安全操作。
antiClickJackingEnabled	X-Frame-Options	站点可以通过确保网站没有被嵌入到别人的站点里面，从而避免 点击劫持攻击。
antiClickJackingOption	X-Frame策略	DENY：页面不允许在frame中展示；SAMEORIGIN：页面可以在相同域名页面的frame中展示；ALLOW-FROM：页面可以在指定来源的 frame 中展示。
antiClickJackingUri	指定来源	页面可以在指定来源的 frame 中展示，示例： http://ip:port 或者 http://ip.* 。注：若是多个地址，需要使用空格隔开。
hstsEnabled	Strict-Transport-Security	通知浏览器，网站禁止使用 HTTP 方式加载，浏览器应该自动把所有尝试使用 HTTP 的请求自动替换为 HTTPS 请求。

参数	名称	参数说明
blockContentTypeSniffingEnabled	X-Content-Type-Options	禁止浏览器的类型猜测行为。
xssProtectionEnabled	X-XSS-Protection	当检测到跨站脚本攻击 (XSS) 时，浏览器将停止加载页面。

2.3.4. 支持 XFF

安全策略 ⓘ / 编辑 ☆

文件防篡改客户端拦截协议头安全支持 XFF反爬虫禁用时间段启停安全序列化安全

解析 XFF 头 ⓘ

内部代理 ⓘ

信任的代理 ⓘ

协议信息请求头 ⓘ

获取主机的请求头 ⓘ

替换本地主机 ⓘ

获取端口的请求头 ⓘ

替换本地端口 ⓘ

缺省 http 端口 ⓘ

缺省 https 端口 ⓘ

☒

10\.\d{1,3}\.\d{1,3}\.\d{1,3}|192\.168\.\d{1,3}\.\d{1,3}|169\.254\.\d{1,3}\.\d{1,3}|168

X-Forwarded-Proto

☐

☐

80

443

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 6. 安全策略的【支持 XFF】

参数	名称	参数说明
XForwardedFor	解析 XFF 头	X-Forwarded-For (XFF) 是用来识别通过 HTTP 代理或负载均衡方式连接到 Web 服务器的客户端最原始的 IP 地址的 HTTP 请求头字段。开启该功能后，将基于代理或负载均衡器的请求头 X-Forwarded-For 来获得连接的原始 IP 地址。

参数	名称	参数说明
internalProxies	内部代理	匹配内部代理的 IP 地址的正则表达式。若它们出现在 remotelPHeader 标头中，则它们将被信任并且不会出现在 proxiesHeader 标头中。
trustedProxies	信任的代理	匹配受信任代理的 IP 地址的正则表达式。若它们出现在 remotelPHeader 标头中，则它们将被信任并出现在 proxiesHeader 标头中。
protocolHeader	协议信息请求头	包含协议信息的 HTTP 标头，通常命名为 X-Forwarded-Proto。若为空，则不会替换 Request 的 scheme、secure、主机名和端口。
hostHeader	获取主机的请求头	从这个请求头取值，用以覆盖 Request.getServerName() 的返回值。若开启了“替换本地主机”，则同时覆盖 Request.getLocalName() 的返回值。
changeLocalName	替换本地主机	若开启，则从“获取主机的请求头”中取值，用以覆盖 Request.getLocalName() 的返回值。
portHeader	获取端口的请求头	从这个请求头取值，用以覆盖 Request.getServerPort() 的返回值。若开启了“替换本地端口”，则同时覆盖 Request.getLocalPort() 的返回值。对于 http 协议，若没有从“获取端口的请求头”中获取到值，则使用“缺省 http 端口”。
changeLocalPort	替换本地端口	若开启，则从“获取端口的请求头”中取值，用以覆盖 Request.getLocalPort() 的返回值。对于 http 协议，若没有从“获取端口的请求头”中获取到值，则使用“缺省 http 端口”。
httpServerPort	缺省 http 端口	对于 http 协议，若没有从“获取端口的请求头”中获取到值，则使用该缺省值。
httpsServerPort	缺省 https 端口	对于 https 协议，若没有从“获取端口的请求头”中获取到值，则使用该缺省值。

2.3.5. 反爬虫

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

序列化安全

反爬虫管理 ⓘ

爬虫会话超时时间 ⓘ

60

识别爬虫 IP ⓘ

识别爬虫 User-Agent ⓘ

[bB]ot.|*Yahoo! Slurp.*|*Feedfetcher-Google.*

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 7. 安全策略的【反爬虫】

参数	名称	参数说明
enableCrawlerSessionManager	反爬虫管理	Web 爬虫在爬取站点时会触发数千个会话的创建，这可能会导致大量内存消耗。此功能确保爬虫与单个会话相关联 - 就像普通用户一样 - 无论他们是否在请求中提供会话令牌。
sessionInactiveInterval	爬虫会话超时时间	指定爬虫会话的会话超时（单位：秒），通常应小于用户会话时间。
crawlerIps	识别爬虫 IP	设置匹配 IP 的正则表达式或通配符 IP（如：168.1.2.*，168.1.4.5-168.1.4.99）来识别爬虫会话。
singleSession	启用单会话	启用单会话功能，开启后，每个IP只会创建一个会话。
crawlerUserAgents	识别爬虫 User-Agent	设置匹配 User-Agent 的正则表达式来识别爬虫。

2.3.6. 禁用时间段

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

序列化安全

禁用时间段 ⓘ

开始时间 ⓘ

0

结束时间 ⓘ

24

* 重复规则 ⓘ

☐ 周日

☐ 周一

☐ 周二

☐ 周三

☐ 周四

☐ 周五

☐ 周六

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 8. 安全策略的【禁用时间段】

参数	名称	参数说明
filterTime	禁用时间段	设置禁止外部访问本服务器的时间段。注：本机访问不受限制。
filterTimeBegin	开始时间	指定的拦截规则在每日的该时间点（小时，24小时制）开始生效。
filterTimeEnd	结束时间	指定的拦截规则在每日的该时间点（小时，24小时制）结束生效。
repeat	重复规则	设置此拦截规则重复生效的规则。

2.3.7. 启停安全

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

序列化安全

System退出检测 ⓘ

启动限制 ⓘ

安全停止 ⓘ

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

Table 9. 安全策略的【启停安全】

参数	名称	参数说明
enabledRejectSystemExit	System退出检测	探测通过 System.exit()、Runtime.exit()、Runtime.halt() 以及 Ctrl+C 等方式停止 TongWeb 服务的行为，并记录相关的调用堆栈。
rejectSystemExit	禁止 System 退出	当 System 退出被检测到时，是否阻止该行为。注：使用停止脚本停止 TongWeb 的行为不受影响。
rejectStart	启动限制	对 TongWeb 的启动进行权限验证，验证通过后可正常启动 TongWeb，否则启动将会终止。
checkedOsUsers	禁止用户	指定不允许启动 TongWeb 的操作系统用户列表，多个用户以英文逗号分隔。
minimumUmask	最小 Umask	指定须为运行 TongWeb 的操作系统用户配置的最小 umask。若配置了该参数，则 TongWeb 会在启动之前去环境变量（参数名为"tongweb_UMASK"）或 -D 参数（参数名为"tongweb_UMASK"）里检查操作系统用户的 umask（若两处都设置则以 -D 参数为准），只有当其值与最小 umask 值作按位与操作得出的值仍为最小 umask 值时才允许启动。注：该配置格式为八进制，须是一个合法的 umask 值。
secureStop	安全停止	在调用 TongWeb 的停止脚本时进行密码验证，输入正确的系统管理员密码才可以停止 TongWeb 服务。

2.3.8. 序列化安全

安全策略 ⓘ / 编辑 ☆

文件防篡改

客户端拦截

协议头安全

支持 XFF

反爬虫

禁用时间段

启停安全

通信

Java原生序列化 ⓘ

黑名单 ⓘ

白名单 ⓘ

RMI 服务主机名 ⓘ

org.codehaus.groovy.runtime.,org.apache.commons.collections.functors.,org.apa

127.0.0.1

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>security

2.4. 在虚拟主机中自定义错误页面

虚拟主机 / 创建 ☆

* 主机名 ?

别名 ?

默认安全域 ?

会话服务器 ?

自定义 Valve ?

自定义错误页面 ?

使用 Json 报告

单点登录 ?

Session 共享 ?

变量名

值

自定义错误页面，数据格式为 code=path，其中 code 指定错误状态码，path 指定自定义错误页面的绝对路径，也可以是相对于 TongWeb 安装目录或域目录的相对路径，多个自定义错误页面需以英文逗号分隔。

属性及属性说明，如下表所示。

持久化位置：conf/tongweb.xml:tongweb>server>service>container>host

Table 10. 虚拟主机的【基本属性】

参数	名称	参数说明
name	主机名	虚拟主机的名称，可作为访问该虚拟主机的域名。注意：避免使用 IP 地址；若使用 IP 地址，则通过此 IP 地址就只能访问此虚拟主机下的应用，可能导致控制台无法访问。
aliases	别名	虚拟主机的别名，别名和主机名一样可作为访问该虚拟主机的域名。多个别名以英文逗号分隔。注意：避免使用 IP 地址，若使用 IP 地址，则通过此 IP 就只能访问此虚拟主机下的应用，可能导致控制台无法访问。
refRealm	默认安全域	此处设置的安全域可作用于所有部署在此虚拟主机上的应用，其优先级低于应用自身设置的安全域。若此虚拟主机同时开启了“单点登录（SSO）”，则优先级高于应用设置的安全域。

参数	名称	参数说明
refSessionHa	会话服务器	选择应用要连接的会话服务器，将应用的 Session 存储到会话服务器。此处设置的会话服务器可作用于所有部署在此虚拟主机上的应用，其优先级低于应用自身设置的会话服务器。若此虚拟主机同时开启了“Session 共享”，则优先级高于应用设置的会话服务器。
addValve	自定义 Valve	自定义 Valve 的全类名，自定义的 Valve 会添加到虚拟主机的 pipeline（valve 链）里，访问应用时执行自定义的操作。自定义的 Valve 需继承 com.tongweb.server.valves.ValveBase 类（所在 jar：\${tongweb.home}/version*/tongweb-web.jar）；在重写 invoke 方法时，需要确保调用“getNext().invoke(request, response)”；在重写其它方法时，需要确保调用对应的 super 方法。多个自定义 Valve 需以英文逗号分隔。注：需在 TongWeb 启动之前，将包含自定义 Valve 的 jar 文件放置到 \${tongweb.base}/lib 下。
customErrorPage	自定义错误页面	自定义错误页面，数据格式为 code=path，其中 code 指定错误状态码，path 指定自定义错误页面的绝对路径，也可以是相对于 TongWeb 安装目录或域目录的相对路径，多个自定义错误页面需以英文逗号分隔。
useJsonReport	使用 Json 报告	开启此选项后，任何导致 HTTP 错误状态码的请求都将收到一个包含错误信息的 JSON 数据格式的响应。若未开启，服务器将继续使用默认的 HTML 数据格式的页面响应。
ssoEnabled	单点登录	是否开启单点登录，默认关闭。开启后，同一虚拟主机下使用相同安全域的应用可以实现多点登录，即登录一次访问多个应用。注：若要启用单点登录功能，则需要首先设置默认安全域。
sessionShareEnabled	Session 共享	是否开启应用间的 Session 共享功能。开启后，同一虚拟主机下的应用可以实现 Session 数据共享。
rewriteEnabled	启用 URL 重写	支持 URL 重写和请求转发，能够在请求到达 Servlet 容器之前对 URL 进行修改，类似于 Apache HTTP 服务器中的 mod_rewrite 模块。
rewriteConfigFile	URL 重写规则文件	指定 URL 重写功能使用的规则文件。

3. SSL 配置相关

SSL 通常为安全检查必配项，在进行 SSL 相关配置时，需要依据以下方案：

1. 购买正式证书，TongWeb 自带测试证书非正式证书，需购买制作正式证书配 SSL。
2. 在负载均衡条件下，证书通常配置在负载设备上，如：硬件 F5、软件 THS。

注意：

不了解证书如何申请，为什么要购买，一般厂商为什么提供不了正式证书？

对以上问题通俗的讲解可参考：<https://blog.csdn.net/zxh2075/article/details/78104510>

3.1. 关于 SSL 安全配置

SSL 相关漏洞和问题如下：

1. CVE-2015-2808：SSL/TLS 受诫礼(BAR-MITZVAH)攻击漏洞。
2. CVE-2014-3566：SSLv3 在降级的旧版加密漏洞（POODLE）。
3. CVE-2016-0800：SSL DROWN 攻击漏洞。
4. CVE-2016-0800：SSL DROWN 攻击漏洞。
5. SSL 证书非正式可信证书等。

解决以上漏洞和方法的方法：

第1步：制作证书由用户方提供

1. 用户制作证书请求时需使用 OpenSSL 最新版本，老版本 OpenSSL 有安全漏洞。
2. 制作的证书密码位数要符合安全要求。
3. 如果是在 THS、Apache、nginx 上配的 SSL，则在 THS、Apache、nginx 上解决漏洞。

第2步：在 TongWeb 上配置 SSL 证书

1. 勾选相应 TLS 协议。
2. 在“启用密码套件”中配置安全的算法。

例如：以下算法：

```
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256,TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA,TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384,TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA,TLS_RSA_WITH_AES_128_CBC_SHA256,TLS_RSA_WITH_AES_128_CBC_SHA
```

3. 在 TongWeb 使用的 JDK 中“jre\lib\security\java.security”配置禁用不安全的 SSL 协议和算法。

如下所示：

```
#JDK8 默认配置如下：
jdk.tls.disabledAlgorithms=SSLv3, TLSv1, TLSv1.1, RC4, DES, MD5withRSA, \
    DH keySize < 1024, EC keySize < 224, 3DES_EDE_CBC, anon, NULL, \
```

```
include jdk.disabled.namedCurves
```

3.2. http 强制跳转 https 端口



